Case 02 · Threat model: the three survivors

A companion document between the POC stage and the spec. Its purpose: before specifying features, understand what each system protects, who might attack it, and where. The defences proposed here become requirements in the spec.

What a threat model is, and how to read this document

A threat model answers four questions: what we are protecting (assets), who might harm it and why (attackers), where they can get in (trust boundaries and attack surfaces), and what stops them and what remains open (defences and residual risk).

A trust boundary is any place where information passes from one party to another that is not trusted to the same degree. For example, the moment a file from a finance ministry's website enters our system. Almost every attack happens on such a boundary.

So that no direction is forgotten, threats are sorted by STRIDE, six categories developed at Microsoft:

- **S, Spoofing:** someone pretends to be someone else.
- **T, Tampering:** someone changes data or code without permission.
- **R, Repudiation:** someone did something and it cannot be proven it was them.
- **I, Information Disclosure:** information reaches someone who should not see it.
- **D, Denial of Service:** someone makes the system stop working.
- **E, Elevation of Privilege:** someone gains a capability they were not supposed to have.

For each threat: who the attacker is, what they do, the damage, the defence, and what remains open even after the defence. "What remains open" is the most important part: a threat model that claims everything is closed is not an honest one.

Uniformity rule: each of the three survivors gets six threats, one per category, at the same level of detail.

1. Maturity Wall Simulator

What we protect

- **Correctness of projections:** a wrong number about a country's debt, published under the tool's name, is the greatest harm.
- **The provenance chain:** the ability to show which official file, and which version, every number came from.
- **Trust in the tool:** if a projection is ever shown to have been faked, no one will quote it again.

Who might attack

- **A speculator:** profits from panic in the bond market, and so wants a frightening projection that looks official.
- **A political actor:** wants to show that a rival's budget "leads to collapse", or that their own "saves the day".

- **A troll or disinformation spreader:** wants a fake screenshot carrying the tool's logo.
- **An opportunistic network attacker:** tries to take down or deface the site with no economic motive.

Trust boundaries

Three crossings: (1) official source → load adapter, (2) engine → output shown to the user, (3) output → the world (screenshots, quotes).

The threats

- **S, spoofing the source:** an attacker serves a file that looks like a debt-office publication (through a fake mirror or poisoned DNS, for example). Damage: the whole projection is built on a fake bond list. Defence: loads only from predefined HTTPS addresses, certificate validation, and a completeness check against the debt the country reports. Remains open: if the official source itself is wrong, we will be wrong with it.
- **T, tampering during load:** a bug or format change at the debt office causes the adapter to read the wrong column (a coupon instead of an amount, say). Damage: a wrong projection that looks plausible. Defence: range checks on every field, comparison with the previous load, and an automatic stop when the change is unusual. Remains open: a small, consistent change can pass every check.
- **R, repudiating the source:** someone quotes "according to the tool, debt will reach 160%", and there is no way to prove which assumptions and data produced it. Damage: an argument the tool cannot settle. Defence: every output carries a fingerprint (hash) of the input file, the engine version and all assumptions, plus a permalink that reproduces exactly the same result. Remains open: partial quotes that drop the assumptions cannot be prevented.
- **I, misuse of the result:** an extreme scenario is presented as a prophecy ("the tool predicts France's collapse"). Damage: feeding the panic the tool exists to understand, not create. Defence: every chart carries its assumptions on it (not just in a footnote), there are no scores or ratings for countries, and extreme scenarios are labelled as such. Remains open: there is no control over what people write on social media.
- **D, taking the service down:** load on the API at a moment of market stress, exactly when everyone wants to check. Damage: the tool is unavailable when it is most needed. Defence: the engine is light and can run in the user's browser, so the server mostly serves static files. Remains open: refreshing the data itself depends on the server.
- **E, changing the defaults:** someone with edit access to the default scenarios quietly changes them (lower growth, say) so that the first projection everyone sees is scarier. Damage: a silent bias for every user. Defence: defaults live in code with a change history, and every change appears in a public log. Remains open: even a "fair" default is a choice.

The bottom line

The main threat here is not a break-in but credibility: a tool whose numbers are quoted must prove where every number came from. What moves to the spec: full provenance for every output, and completeness checks on every load.

2. Fire-Sale Cascade Simulator

What we protect

- **Model correctness:** a simulation that behaves differently from what it claims is worse than no simulation.
- **Input data, if they are ever real:** today the tool works on distributions. But the moment someone loads real balance sheets into it, it becomes a store of very sensitive information.
- **Trust in the result:** the difference between "an educational scenario" and "a forecast".

Who might attack

- **A speculator:** wants to "prove" that a particular institution is collapsing, to profit from a short position.
- **A competitor of a financial institution:** wants to publish a simulation that makes the rival look weak.
- **A naive user:** loads their institution's real data into a public tool without understanding the risk.
- An opportunistic network attacker.

Trust boundaries

Three crossings: (1) user → world definition (parameters or data), (2) engine → result, (3) result → the world.

The threats

- **S, spoofing a calibration:** someone publishes an "official reproduction of the 2022 crisis using the tool" with parameters of their own choosing. Damage: a biased result that looks like the tool's own output. Defence: calibrated worlds are stored as signed files with an identifier, and the tool shows clearly when a world is not from the official library. Remains open: nothing can stop someone claiming they used the tool.
- **T, engineering the result:** deliberately choosing parameters (low market depth, narrow leverage thresholds) to produce a frightening spiral. The POC showed this is especially easy, because the outcome jumps within a narrow range. Damage: a simulated "proof" of collapse. Defence: every result is shown together with a sensitivity check showing how much it depends on each parameter, and the default is a range rather than a number. Remains open: a user who screenshots only the scary chart.
- **R, a result without history:** there is no way to reproduce how a given result was reached. Defence: a fixed seed, and every run gets a link that reproduces it exactly (parameters, seed, version). Remains open: nothing material; this problem is fully solved.
- **I, leaking real balance sheets:** a user loads real balance sheets and they are stored on the server, in a log or in a share link. Damage: exposure of extremely sensitive business information. Defence: the whole simulation runs in the browser, no data are sent to a server, and share links contain only distribution parameters, never institution data. Remains open: what the user does with their own computer.
- **D, resource exhaustion:** a giant sweep (millions of worlds) freezes the browser. Damage: low, it hurts only the user. Defence: a cap on sweep size, and running in a Web Worker so the page does not freeze. Remains open: low.

- **E, turning a learning tool into a decision tool:** an institution starts using the results as the basis for investment or supervisory decisions. Damage: real decisions on an uncalibrated model. Defence: a prominent statement that the tool is for exploration, not a substitute for official stress tests. Remains open: this is an escalation of authority, not of technical permission, and it has no technical fix.

The bottom line

The main threat here is a biased result that looks credible, and the POC showed why: the answer jumps within a narrow range of a single parameter. And there is a twist: the moment the tool receives real data, it turns from a learning model into a sensitive target. What moves to the spec: a sensitivity check with every result, and local-only execution.

3. Private Exposure Registry

What we protect

- **The secrecy of each participant's data:** that is the system's entire promise.
- **Correctness of the aggregate result:** a regulator deciding on a wrong sum.
- **Participants' identity:** the very fact that a particular fund participates can be sensitive.

Who might attack

- **A curious server:** the operator of one of the servers trying to learn what a particular fund holds.
- **Two colluding servers:** combining their shares to reconstruct.
- **A competing participant:** wants to learn another fund's exposures through the results.
- **A concealing participant:** reports lower exposure than the truth to look safer.
- **An outside actor:** tries to intercept communication or take a server down.

Trust boundaries

Four crossings: (1) participant → servers (the shares), (2) server → server (coordination), (3) servers → the release gate, (4) result → regulator.

The threats

- **S, a Sybil attack (fake funds):** the threshold of 5 participants per cell sounds safe. But an attacker who wants to learn the value of the only fund in a rare sector registers 4 fake funds reporting zero in that cell. The threshold is met, the cell opens, and the attacker subtracts their zeros to get the real fund's value. Damage: a complete break of secrecy. Defence: participants are registered only through a regulator, with a key issued to every genuinely supervised entity, and DP noise that blurs even a cell that opens. Remains open: if the regulator itself registers fake participants.
- **T, a server tampering with shares:** a malicious server alters its share, and the aggregate result changes without anyone noticing. The POC assumed "honest but curious" servers, so this is not handled there. Damage: a regulator sees a wrong picture. Defence: moving to a protocol with authentication codes (MACs, as in SPDZ) that detect any change to a share. Remains open: a significant performance cost that must be measured.

- **R, a participant who denies:** a participant claims "I didn't report that", or "I reported something else". Damage: no way to enforce correct reporting or prove what was sent. Defence: each participant signs a cryptographic commitment to its values before splitting. The commitment reveals nothing, but it can be opened in an audit. Remains open: a commitment proves what was sent, not that it was true.
- **I, a differencing attack:** a question about "all sectors" followed by a question about "all sectors except energy", and the difference reveals energy even if its own cell was blocked. Damage: bypassing the threshold through repeated questions. Defence: a closed query catalog (no free-form questions), and a total privacy budget that runs out after a set number of queries. Remains open: even a closed catalog needs checking for such pairs of questions.
- **D, one server goes down:** in a 3-of-3 scheme every share is needed. One unavailable server stops everything. Damage: no aggregate picture exactly at a moment of stress, when it is most needed. Defence: moving to 2-of-3 Shamir secret sharing, where any two servers suffice. Remains open: the price is that two colluding servers can now reconstruct. This is a real trade-off between availability and secrecy, and it must be decided in the spec.
- **E, a lying participant:** cryptography protects secrecy, not truth. A fund can report lower exposure than the truth and no one will see. Damage: the aggregate picture looks safer than reality. Partial defence: encrypted range proofs that show a value is plausible without revealing it, and cross-checks against audited reports the regulator already holds. Remains open: this is the largest remaining risk, and it has no complete cryptographic solution.

The bottom line

Here the threat model changes the design more than in the other two. The POC proved secrecy against curious servers, but not against a malicious server, a fake fund, or a lying participant. What moves to the spec: registration through a regulator, share authentication, a privacy budget, and a decision between 3-of-3 and 2-of-3.

What we learned from comparing the three models

- **In both simulators, the main threat is the credibility of the result:** a wrong or biased number that looks official.
- In the Registry, the main threat is secrecy, and above it the truth of the data.
- **One threat recurs in all three:** someone who screenshots only the frightening part. It has no technical fix, only a design in which the assumptions are attached to the result.
- Every "remains open" in these lists is a question the spec will have to answer, or admit it cannot.